



FindMyFlick ZAP Report3

Sites: <https://data-edge.smartscreen.microsoft.com> <https://telem-edge.smartscreen.microsoft.com> <https://nav-edge.smartscreen.microsoft.com> <https://www.bing.com> <https://www.findmyflick.com> <http://www.findmyflick.com>

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	3
Informational	3

Alerts

Name	Risk Level	Number of Instances
Strict-Transport-Security Header Not Set	Low	5
Timestamp Disclosure - Unix	Low	1
X-Content-Type-Options Header Missing	Low	5
Information Disclosure - Suspicious Comments	Informational	1
Modern Web Application	Informational	3
Re-examine Cache-control Directives	Informational	1

Alert Detail

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	

Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)
Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Node Name	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3 ()({executionTime,random,samplingRates:{evaluateModel,serverCall},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},correlationId,identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},userAgent,events:[{\$type,nam...})
Method	POST
Attack	
Evidence	
Other Info	

Instances	5
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	1776807662
Other Info	1776807662, which evaluates to: 2026-04-21 17:41:02.
Instances	1
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://www.findmyflick.com/robots.txt
Node Name	http://www.findmyflick.com/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json

Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	<code>https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId})</code>
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	<code>https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId})</code>
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	<code>https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)</code>
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

Instances	5
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	https://www.findmyflick.com/assets/index-D2Q-SaUN.js
Node Name	https://www.findmyflick.com/assets/index-D2Q-SaUN.js
Method	GET
Attack	
Evidence	or(`Failed to fetch user`);r(await t.json())
Other Info	The following pattern was used: <code>\bUSER\b</code> and was detected in likely comment: <code>"//,``).split(`/`);h=`'+m.replace(/^V/,``).split(`/`).slice(e.length).join(`/`)}let g=oe(e,{pathname:h});T(d g!=null,`No route", see evidence field for the suspicious comment/snippet.</code>
Instances	1
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://www.findmyflick.com
Node Name	http://www.findmyflick.com
Method	GET
Attack	
Evidence	<code><script type="module" crossorigin src="/assets/index-D2Q-SaUN.js"></script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.findmyflick.com/
Node Name	https://www.findmyflick.com/
Method	GET
Attack	

Evidence	<script type="module" crossorigin src="/assets/index-D2Q-SaUN.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.findmyflick.com/sitemap.xml
Node Name	https://www.findmyflick.com/sitemap.xml
Method	GET
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-D2Q-SaUN.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015